

TP : Analyse Manuelle et État des Lieux Initial (Windows & Linux)

Objectifs du TP

1. Dresser manuellement l'inventaire de la surface d'attaque d'un système sans outil d'automatisation.
2. Détecter les services et ports superflus ouverts sur le réseau.
3. Identifier les configurations à risque concernant les comptes, les privilèges et les permissions.
4. Établir une matrice de référence qui servira de base comparative pour les scans automatisés de l'après-midi.

Contexte

Vous venez de recevoir les accès à deux serveurs récemment installés dans l'infra : un serveur Linux et un serveur Windows Server.

Partie 1 : Audit Manuel sous Linux

Connectez-vous en session SSH sur votre machine Linux via Guacamole.

1.1 Identification des comptes et privilèges

L'objectif est de vérifier qui a accès au système et qui dispose des privilèges administrateur (root).

1. Affichez la liste des comptes disposant d'un interpréteur de commandes interactif (bash, sh) :
`grep -E '(/bin/bash|/bin/sh)$' /etc/passwd`
 2. Vérifiez si d'autres comptes ont un identifiant utilisateur égal à zéro (UID 0, équivalent à root) :
`awk -F: '($3 == "0") {print $1}' /etc/passwd`
 3. Listez les comptes membres du groupe à privilèges sudo ou wheel :
`getent group sudo || getent group wheel`
- **Questions :**
 - Combien de comptes interactifs existent ? Sont-ils tous légitimes ?
 - Le mot de passe du compte root est-il configuré ou le compte est-il verrouillé ?

1.2 Cartographie des ports ouverts et démons en écoute

Vérifiez quels services acceptent des connexions entrantes.

1. Listez tous les ports TCP et UDP actuellement en écoute ainsi que le processus associé :
`ss -tulpen`
2. Vérifiez la liste des services système actuellement actifs au démarrage :
`systemctl list-unit-files --type=service --state=enabled`

- **Questions :**

- Quels ports écoutent sur 0.0.0.0 (accessible depuis tout le réseau) par rapport à 127.0.0.1 (local uniquement) ?
- Des services non indispensables (serveur d'impression CUPS, service RPC, serveur mail local) sont-ils en cours d'exécution ?

1.3 Audit des droits et détection des binaires SUID / SGID

Recherchez les fichiers exécutables s'exécutant avec les droits du propriétaire (root).

1. Lancez la recherche de tous les exécutables portant le bit SUID dans le système de fichiers :
`find / -perm -4000 -type f -exec ls -la {} + 2>/dev/null`
2. Vérifiez les permissions des fichiers critiques d'authentification :
`ls -la /etc/passwd /etc/shadow /etc/sudoers`

- **Questions :**

- Le fichier /etc/shadow est-il bien protégé en lecture exclusive pour root (-rw-r----- ou -----) ?
- Repérez-vous un binaire inhabituel ou détournable (ex: éditeur de texte, interpréteur) porteur du bit SUID ?

Partie 2 : Audit Manuel sous Windows Server

Connectez-vous en session RDP sur votre machine Windows Server via Guacamole, puis ouvrez une console **PowerShell en tant qu'Administrateur**.

2.1 Audit des utilisateurs et groupes locaux

1. Listez les utilisateurs locaux présents sur la machine :
`Get-LocalUser`
2. Vérifiez les membres du groupe très critique des Administrateurs locaux :
`Get-LocalGroupMember -Group "Administrateurs"`

3. Contrôlez l'état du compte invité (Guest) et du compte Administrateur local par défaut :
Get-LocalUser -Name "Invité", "Administrateur" | Select-Object Name, Enabled, PasswordRequired, LastLogon

- **Questions :**

- Des comptes non nécessaires ou de test sont-ils activés ?
- Le compte Administrateur par défaut a-t-il été renommé ?

2.2 Analyse des ports et processus associés

1. Listez l'ensemble des ports TCP en état d'écoute (Listen) avec l'identifiant du processus (PID) :
Get-NetTCPConnection -State Listen | Select-Object LocalAddress, LocalPort, OwningProcess | Sort-Object LocalPort
2. Identifiez le nom du service ou de l'application correspondant à un PID suspect (exemple pour le PID 1234) :
Get-Process -Id 1234 | Select-Object Id, ProcessName, Path

- **Questions :**

- Le port RDP (3389) écoute-t-il sur toutes les adresses ?
- D'autres ports comme WinRM (5985), SMB (445) ou RPC (135) sont-ils ouverts sans restriction apparente ?

2.3 Partages réseau et état du pare-feu

1. Affichez les dossiers partagés sur la machine :
Get-SmbShare
2. Contrôlez l'état d'activation du Pare-feu Windows sur les trois profils réseau (Domaine, Privé, Public) :
Get-NetFirewallProfile | Select-Object Name, Enabled, DefaultInboundAction, DefaultOutboundAction

- **Questions :**

- Les partages administratifs par défaut (C\$, ADMIN\$) sont-ils présents ?
- L'un des profils de pare-feu est-il désactivé ?

Partie 3 : Synthèse de la Surface d'Attaque (Livrable)

Complétez le tableau récapitulatif suivant à partir de vos observations. Ce tableau servira de point de comparaison direct avec le rapport du scanner de vulnérabilités :

Composant analysé	Machine Linux	Machine Windows Server	Risque potentiel identifié
Comptes & Privilèges			
Ports exposés (0.0.0.0)			
Services inutiles actifs			
Permissions / Partages			
Posture Pare-feu			

Critères de réussite du TP

- L'ensemble des commandes de diagnostic a été exécuté sur les deux OS.
- Les ports et services superflus sont listés et justifiés.
- La fiche de synthèse est complétée et prête pour le module de l'après-midi.